

AI READINESS & RISK ASSESSMENT - RESULTS REPORT

Grant Thornton Bahrain | Professional services | Assessment date: 24/09/2026

Scope: Whole organisation - Firm-wide AI adoption across Audit, Tax, Advisory and internal functions | Completed by: AI Service Line Lead (Director, Risk Advisory)
Framework basis: NSW AI Assessment Framework (inherent risk) | GT AI Ready7 (7 pillars) | GT AI RCM v2.1 (controls) | ISO/IEC 42001, NIST AI RMF, EU AI Act, Bahrain PDPL

1. EXECUTIVE SUMMARY			
OVERALL AI READINESS	MATURITY LEVEL	INHERENT RISK TIER	OVERALL AI RISK EXPOSURE
62%	Informed	Medium	Moderate
AI Ready7 scale: <50% Partial 50-70% Informed 70-90% Repeatable 90%+ Adaptive	Awareness and some defined practices exist, but they are not consistently implemented.	43% of maximum inherent risk. No override applied	Combines inherent risk tier and readiness maturity (see Methodology)

RECOMMENDED PATHWAY	PROCEED WITH CONDITIONS
Continue AI adoption, but address the identified gaps through a time-bound remediation plan (within 90 days for priority items). Obtain SME review (risk, privacy, security) for new AI use cases.	

Based on the responses provided, Grant Thornton Bahrain has an overall AI readiness score of 62%, corresponding to the 'Informed' maturity level: awareness and some defined practices exist, but they are not consistently implemented. Its AI use profile indicates a MEDIUM inherent risk tier (43% of maximum inherent risk), resulting in an overall AI risk exposure rating of MODERATE. The strongest area is Training & Development (75%) and the area requiring most attention is Business Alignment (50%). Recommended pathway: PROCEED WITH CONDITIONS. Continue AI adoption, but address the identified gaps through a time-bound remediation plan (within 90 days for priority items). Obtain SME review (risk, privacy, security) for new AI use cases.

2. READINESS BY AI READY7 PILLAR			
Pillar	Score	Maturity	Progress
Business Alignment	50%	Informed	
Governance & Ethics	56%	Informed	
Training & Development	75%	Repeatable	
Data & Quality	75%	Repeatable	
Architecture & Technology	50%	Informed	
Protect AI Systems	50%	Informed	
Protection from AI Threats	75%	Repeatable	
OVERALL	62%	Informed	Target 70%

Pillar	Score
Business	50
Governance	56
Training	75
Data	75
Architecture	50
Protect AI	50
AI Threats	75
Overall Average	62

Pillar	Potential risk if the pillar is not strengthened (shown where score < 90%)
Business Alignment	Poor AI direction leads to inconsistent use, unmanaged risk, duplication and weak accountability, slowing adoption and reducing trust.
Governance & Ethics	Weak AI governance (policies, guardrails, risk assessment, ownership) increases misuse, compliance breaches and uncontrolled AI sprawl.
Training & Development	Low AI literacy and skills increase unsafe use, susceptibility to AI-enabled threats, biased outcomes and limit effective adoption.
Data & Quality	Weak data governance and oversight increase the risk of breaches, bias, data misuse, lack of transparency and non-compliance.
Architecture & Technology	Weak AI architecture and controls increase security gaps, integration risk, undetected failures and unsustainable costs.
Protect AI Systems	Weak AI security practices increase the risk of unauthorised access, data leakage, vulnerable deployments and undetected misuse.
Protection from AI Threats	Weak AI-threat detection and response increase exposure to deepfakes, AI-crafted attacks and delayed response.

3. AI USE & INHERENT RISK PROFILE (AIAF-based)			
Factor	Your response	Risk level	Implication
A1 AI use profile	Approved enterprise GenAI tools and AI features embedded in business software across teams	Medium	AI is part of day-to-day work. Exposure spans data protection, output quality, vendor dependence and consistent human review.
A2 Decision impact	Customer- or client-facing outputs with limited individual impact (e.g., FAQ chatbots, marketing content)	Medium	External stakeholders see AI outputs - disclosure, accuracy and reputational controls apply (e.g., EU AI Act Art. 50 where relevant).
A3 Data sensitivity	Confidential business or client information	Medium	Confidentiality and contractual obligations apply; vendor data-use terms are critical.
A4 Oversight & reversibility	A qualified human reviews and approves every AI output before it is used	Low	Effective 'human-in-charge' control if reviewers are trained and have time and authority to challenge.
Inherent risk tier: MEDIUM (43% weighted inherent-risk score)		<i>No override applied</i>	

4. RESPONSIBLE-AI PRINCIPLE COVERAGE (NSW AIAF ethics principles)			
Principle	Coverage	Assessment	Informed by questions
Fairness	63%	Partially addressed	Q9, Q11
Privacy & Security	69%	Partially addressed	Q7, Q11, Q13, Q14
Transparency & Explainability	50%	Partially addressed	Q9, Q15
Accountability	56%	Partially addressed	Q5, Q7, Q8, Q15
Human, Social & Environmental Wellbeing	50%	Partially addressed	Q6, Q8
Human-Centred Values	63%	Partially addressed	Q9, Q10
Reliability & Safety	50%	Partially addressed	Q12, Q13, Q15
Contestability	50%	Partially addressed	Q9, Q15

5. DETAILED FINDINGS & RECOMMENDATIONS			
Area	Your response & score	Potential risk	Recommended action
Q5 AI strategy, ownership & risk appetite Business Alignment AI Ready7: 1.1 ☆ Recommended	50% - Partially met Executive sponsor named and AI strategy drafted or approved, but risk appetite and experimentation boundaries not defined	Lack of executive direction leads to inconsistent AI use, unmanaged risk-taking, poor-quality outputs and fragmented adoption.	Define AI risk appetite, tolerances and approved experimentation ('sandbox') boundaries; communicate them organisation-wide. Controls: GL-1, GL-3, RM-6
Q6 Use-case portfolio & value realisation Business Alignment AI Ready7: 1.2, 1.3 ☆ Recommended	50% - Partially met Use-case intake exists and initiatives are prioritised, but benefits are not systematically tracked	Duplicated or low-value AI investment, shadow AI and inability to demonstrate return on investment.	Define benefit KPIs (financial and non-financial) at approval and assign benefit owners. Controls: GL-6, GL-5
Q7 AI policy, acceptable use & regulatory compliance Governance & Ethics AI Ready7: 2.1, 2.2 ⚙ Compliance Obligation	75% - Largely met AI policy enforced with staff acknowledgement; obligations register maps regulations to controls and owners	Misuse of AI, data leakage and breach of legal or regulatory requirements, with exposure to penalties, licence conditions and reputational harm.	Establish monthly regulatory horizon scanning and periodic compliance testing with evidence retention. Controls: GL-5, RO-1, RO-5
Q8 AI inventory & risk / impact assessment Governance & Ethics AI Ready7: 2.4, 2.5 ⚠ Mandatory Requirement	50% - Partially met AI register with owners; risk assessments performed for some AI systems using a documented method	Deployment of vulnerable, non-compliant or harmful AI systems and unknown AI exposure across the organisation and its supply chain.	Extend assessments to all AI systems and third-party AI; set approval authority by risk tier. Controls: GL-8, RM-2, RM-5, TP-2
Q9 Responsible-AI guardrails & human oversight Governance & Ethics AI Ready7: 2.3, 5.2 ⚙ Ethical Consideration	50% - Partially met AI committee / CoE established; guardrails defined for some areas (e.g., human review of outputs)	Biased or harmful outcomes, undisclosed AI use and lack of accountability for AI-supported decisions.	Apply mandatory human-in-charge controls and AI disclosure to all relevant AI; require committee approval for High / Critical uses. Controls: GL-7, RS-1, RS-4, RS-5, CO-1, CO-3

Q10 AI literacy & capability Training & Development AI Ready7: 3.1, 3.2, 3.3, 3.4 ☞ Compliance Obligation	75% - Largely met Mandatory AI literacy before tool access; role-based pathways for developers, oversight staff and leaders; scenario-based security awareness	Unsafe use, susceptibility to AI-enabled threats and poor adoption; non-compliance with the EU AI Act Art. 4 AI-literacy duty where applicable.	Measure competence, refresh annually, and build an AI champions network and workforce plan. Controls: GL-4, RS-9
Q11 Data governance, quality & privacy for AI Data & Quality AI Ready7: 5.1, 5.3, 5.4, 5.5 ☞ Compliance Obligation	75% - Largely met Data readiness assessed before approval; lineage and quality monitored; minimisation, anonymisation and prompt redaction applied; DPIAs standard	Data breaches, PDPL non-compliance, and biased or inaccurate outputs from poor-quality or unsuitable data.	Automate data-quality and lineage monitoring; operationalise data-subject rights and transfer assessments for AI. Controls: LC-1, SE-4, PR-1, PR-4, PR-5, PR-6
Q12 AI architecture, integration & monitoring Architecture & Technology AI Ready7: 4.1, 4.2, 4.3, 4.4, 4.5 ☆ Recommended	50% - Partially met Reference architecture drafted; approved platforms and integration patterns for most AI; basic performance monitoring	Inconsistent and insecure implementations, undetected model drift or failure, excessive agent privileges and unsustainable AI costs.	Centralise API / access control for AI, define agent execution authority and implement drift / performance monitoring with thresholds. Controls: LC-2, LC-3, LC-8, LC-12, OM-1, OM-4, RM-6
Q13 Securing AI systems Protect AI Systems AI Ready7: 6.1, 6.2, 6.3, 6.4, 6.5 ⚠ Mandatory Requirement	50% - Partially met AI-specific threats (e.g., prompt injection, data leakage) assessed for some systems; access controls and logging in place	Unauthorised access, model compromise, data exfiltration through AI and undetected misuse.	Introduce AI red teaming before release, runtime guardrails (input / output filtering) and audit logging. Controls: SE-2, SE-3, SE-6 to SE-10, OM-2, AA-3
Q14 Defending against AI-enabled threats Protection from AI Threats AI Ready7: 7.1, 7.2, 7.3, 7.4, 7.5 ☆ Recommended	75% - Largely met Deepfake-resilient verification for payments and sensitive requests; behaviour-based detection; AI incident playbooks exercised	Deepfake-enabled fraud, account compromise and faster, more scalable attacks that outpace defences.	Adopt continuous exposure management and AI-specific red teaming; reduce patch cycles to days. Controls: AT-1, AT-2, AT-3, AT-4
Q15 AI incidents, monitoring & assurance Governance & Ethics AI Ready7: 2.2, 7.4 ☞ Compliance Obligation	50% - Partially met AI incident categories and escalation defined; ad hoc reviews of AI controls	Delayed response to AI failures, missed regulatory notifications and lack of defensible evidence for regulators, auditors and clients.	Include AI governance in the internal-audit plan and obtain assurance evidence from AI vendors. Controls: IM-1, IM-2, IM-3, AA-1, AA-2, RO-4

6. TOP 5 PRIORITY ACTIONS

Ranked by size of gap, weighted for compliance / mandatory requirements and the organisation's inherent risk tier.

#	Area	Score	Action	Timing
1	AI inventory & risk / impact assessment	50%	Extend assessments to all AI systems and third-party AI; set approval authority by risk tier.	Immediate (0-3 months)
2	Securing AI systems	50%	Introduce AI red teaming before release, runtime guardrails (input / output filtering) and audit logging.	Immediate (0-3 months)
3	AI incidents, monitoring & assurance	50%	Include AI governance in the internal-audit plan and obtain assurance evidence from AI vendors.	Immediate (0-3 months)
4	AI strategy, ownership & risk appetite	50%	Define AI risk appetite, tolerances and approved experimentation ('sandbox') boundaries; communicate them organisation-wide.	Short term (3-6 months)
5	Use-case portfolio & value realisation	50%	Define benefit KPIs (financial and non-financial) at approval and assign benefit owners.	Short term (3-6 months)

7. SUGGESTED IMPLEMENTATION ROADMAP

Horizon	Area	Action	Controls
Immediate (0-3 months)	AI inventory & risk / impact assessment	Extend assessments to all AI systems and third-party AI; set approval authority by risk tier.	GL-8, RM-2, RM-5, TP-2
Immediate (0-3 months)	Securing AI systems	Introduce AI red teaming before release, runtime guardrails (input / output filtering) and audit logging.	SE-2, SE-3, SE-6 to SE-10, OM-2, AA-3
Immediate (0-3 months)	AI incidents, monitoring & assurance	Include AI governance in the internal-audit plan and obtain assurance evidence from AI vendors.	IM-1, IM-2, IM-3, AA-1, AA-2, RO-4
Short term (3-6 months)	AI strategy, ownership & risk appetite	Define AI risk appetite, tolerances and approved experimentation ('sandbox') boundaries; communicate them organisation-wide.	GL-1, GL-3, RM-6
Short term (3-6 months)	Use-case portfolio & value realisation	Define benefit KPIs (financial and non-financial) at approval and assign benefit owners.	GL-6, GL-5
Short term (3-6 months)	Responsible-AI guardrails & human oversight	Apply mandatory human-in-charge controls and AI disclosure to all relevant AI; require committee approval for High / Critical uses.	GL-7, RS-1, RS-4, RS-5, CO-1, CO-3
Short term (3-6 months)	AI architecture, integration & monitoring	Centralise API / access control for AI, define agent execution authority and implement drift / performance monitoring with thresholds.	LC-2, LC-3, LC-8, LC-12, OM-1, OM-4, RM-6
Medium term (6-12 months)	AI policy, acceptable use & regulatory compliance	Establish monthly regulatory horizon scanning and periodic compliance testing with evidence retention.	GL-5, RO-1, RO-5
Medium term (6-12 months)	AI literacy & capability	Measure competence, refresh annually, and build an AI champions network and workforce plan.	GL-4, RS-9
Medium term (6-12 months)	Data governance, quality & privacy for AI	Automate data-quality and lineage monitoring; operationalise data-subject rights and transfer assessments for AI.	LC-1, SE-4, PR-1, PR-4, PR-5, PR-6
Medium term (6-12 months)	Defending against AI-enabled threats	Adopt continuous exposure management and AI-specific red teaming; reduce patch cycles to days.	AT-1, AT-2, AT-3, AT-4

8. REGULATORY & STANDARDS CONSIDERATIONS

Applicability is based on the Profile answers; the readiness signal uses the most relevant question scores. Not legal advice - confirm obligations with legal counsel.

Law / regulation / standard	Applies?	Readiness signal	Key considerations
Bahrain Personal Data Protection Law (Law No. 30 of 2018)	Yes	On track	Lawful basis and notice for AI processing; DPIAs; security; data-subject rights incl. objection to automated processing; cross-border transfer rules for AI services hosted outside Bahrain (RCM PR-1 to PR-6).
iGA General Policy for the Use of AI (2025) & GCC Guiding Manual on the Ethics of AI Use	Reference	Partial gap	National AI policy pillars (compliance, adoption, awareness, cooperation) and GCC ethics principles - mandatory reference for government entities and good practice for all (RCM GL-1, GL-4, RS-series).
Central Bank of Bahrain Rulebook (HC, RM, OM, BC modules)	No	Partial gap	Board oversight, risk management, cyber security, outsourcing and consumer-protection requirements apply to AI; expect model validation for material models and notification of material outsourcing (RCM LC-9, TP-3, AT-3).
EU AI Act (Regulation 2024/1689) - general obligations	Yes	On track	Extraterritorial reach. Prohibited practices (Art. 5) and AI literacy (Art. 4) apply since Feb 2025; GPAI rules since Aug 2025; transparency (Art. 50) from Aug 2026 (RCM RM-5, GL-4, CO-1, LC-7).
EU AI Act - high-risk AI systems (Annex III)	Check	Partial gap	Decisions on credit, employment, insurance, essential services etc. may be high-risk: risk management, data governance, logging, human oversight, FRIA and registration (timelines subject to the EU Digital Omnibus outcome) (RCM RO-6).
KSA / UAE / GCC regimes (SDAIA AI Ethics, KSA PDPL, UAE AI Charter, DIFC Regulation 10, QCB AI Guideline)	Yes	On track	Include in the AI obligations register; align data-transfer, ethics and sector AI requirements across GCC operations (RCM RO-5).
ISO/IEC 42001:2023 AI management system	Build first	Partial gap	International certifiable standard for AI governance; demonstrates trustworthy AI to clients and regulators. Recommended once readiness reaches 'Repeatable' (RCM AA-2).
Bahrain draft AI Regulation Law (Shura Council, 2024)	Monitor	On track	Proposed standalone AI law (38 articles) with a new regulator and penalties - not yet in force. Maintain horizon scanning (RCM RO-5).

9. HOW GRANT THORNTON CAN HELP

GT AI service line	Relevance	How we help
AI Governance, Risk & Compliance	Advised	AI governance framework & policies, AI register, risk & impact assessments (GT AI Risk Assessment Framework), RCM-based compliance reviews, ISO/IEC 42001 readiness.
AI Strategy & Roadmap	Advised	Situational / SWOT analysis, AI strategy and risk appetite, use-case prioritisation, value-realisation KPIs and phased roadmap.
Training & Awareness	Optional	AI literacy programmes, role-based pathways, immersive labs, deepfake & AI-phishing simulations, leadership workshops.
AI-Driven Automation & Architecture	Advised	Technology evaluation and selection, reference architecture, AI integration and monitoring. GT AI apps in preparation: AI-powered Business Continuity (BCP) tool and AI-powered Financial Statements tool.
AI Security & Cyber Resilience	Advised	AI security audits (GT AI Security & Agent Audit Checklist), AI red teaming, secure AI agents (ISACA 2026 baseline), deepfake-resilient processes.

10. NEXT STEPS & SIGN-OFF

1. Review this report with the executive sponsor and AI / risk committee.
2. Validate responses with evidence (the level selected should be demonstrable).
3. Assign owners and dates in the '4. Action Plan' sheet for all Immediate and Short-term actions.
4. For individual AI systems rated High or Critical, perform a use-case risk assessment (GT AI Risk Assessment Toolkit).
5. Re-run this assessment in 6-12 months or after significant AI adoption or regulatory change to track progress.

Role	Name	Signature	Date
Assessment completed by	AI Service Line Lead		
Reviewed by (risk / compliance)			
Executive sponsor			

Methodology: Part A (4 questions) derives an inherent-risk tier from the NSW AI Assessment Framework risk factors (AI use, decision impact, data sensitivity, oversight & reversibility). Part B (11 questions) scores readiness 0-100% across the 7 GT AI Ready7 pillars; pillar scores are averaged equally into the overall score and mapped to the AI Ready7 maturity scale. Exposure combines tier and maturity. Recommendations reference the GT AI RCM v2.1 controls. Disclaimer: this is a self-assessment based on the responses provided and has not been independently verified by Grant Thornton. It is not an audit, certification or legal opinion. (c) 2026 Grant Thornton Bahrain. All rights reserved.